Authenticated is ~~not~~ authorised.

Securing API-driven loan disbursements with the Lending Transaction Authorisation Framework (LTAF)

LESSONS FROM THE OCTOBER 2026 NBFC PAYMENT-API ATTACKS



~₹300 crore
reported NBFC losses in about two months

~150
complaints and FIRs reportedly filed

183
unauthorised transfers to 52 accounts in 87 minutes (one NBFC)

Critical
CERT-In advisory CIAD-2026-0046 (9 Oct 2026)

Sources: Economic Times via Elets BFSI, 29 Oct 2026 (estimate; no official consolidated figure) · Siasat, 23 Oct 2026 · CERT-In [1]. Figures as reported, not independently verified.



Kesava Rao Sanapathi
BFSI expert · 12+ years in digital lending, credit risk, underwriting policy and lending-technology transformation across India and the UAE.
linkedin.com/in/kesava-rao-sanapathi-4a9927104
+91 95817 70040

A practical framework to ensure that every loan disbursement is independently authorised, verified and enforced — without adding friction to the digital lending journey.

01 The controls existed. They were checked in the wrong place.

The attackers did not break bank security. They became the lender.

From compromised lender servers, they called disbursement APIs with valid partner-bank credentials and pushed payouts for loans that did not exist, often within minutes [1].

Lenders already eSign loan documents, penny-drop bank accounts and approve disbursements in their loan systems. Every one of those checks is verified inside the lender's own systems, which is exactly where the attacker sat.

The bank confirmed who was calling. Nobody independent confirmed that the payment was a genuine disbursement.

TODAY — ILLUSTRATIVE

Loan ref	LN-48213
Amount	₹4,90,000.00
Beneficiary	XXXXXX7712 · IMPS

mTLS, OAuth token, allowlisted IP	valid
Approved loan LN-48213?	not checked
Disbursement token	not required
Beneficiary name check	not performed

PAID TO MULE

Every caller check passed, so the bank released the funds.

WITH LTAF — ILLUSTRATIVE

Loan ref	LN-48213
Amount	₹4,90,000.00
Beneficiary	XXXXXX7712 · IMPS

mTLS, OAuth token, allowlisted IP	valid
Registry: approved loan LN-48213?	none on record
Disbursement token (DAT)	not issued
Bank validator	no matching DAT

REJECTED

No approved record, so no token. The bank holds the payment and the attempt is logged outside the lender.

THE ATTACK PATTERN [1]

01

Inside the perimeter

Web shells and malware on lender servers. Gateway and bank credentials stolen. Calls made from whitelisted infrastructure.

02

No matching loan

Dummy reference IDs, amounts above limits, rapid IMPS and NEFT transfers to mule accounts across banks.

03

Tracks covered

Logs deleted or truncated and endpoint protection tampered with, slowing investigation.

> **API authentication tells the bank who is calling. A loan disbursement also needs proof that this payment is an approved disbursement: this loan, this amount, this account, once.**

02 The idea: verify every disbursement outside the lender

Every genuine loan disbursement is preceded by a record: a sanctioned loan, an approved amount and tranche, and a verified destination account. The **Lending Transaction Authorisation Framework (LTAF)** moves the verification of that record out of the lender's systems and makes the disbursing bank enforce it.

THE LTAF PRINCIPLE

Every loan disbursement is verified outside the lender's systems, against the approved disbursement record and the beneficiary's bank. An independent Registry issues a single-use Disbursement Authorisation Token (DAT), and the bank releases funds only after verifying it.

Zero-touch by design. The borrower journey stays the same and there is no manual approval queue.

WHAT CHANGES	TODAY		WITH LTAF
Where verification happens	Lender's own servers	→	Independent Registry and the disbursing bank
What the bank trusts	The caller's credentials	→	A single-use token bound to loan, amount and account
Where the audit trail lives	Lender logs, which attackers deleted	→	An out-of-perimeter ledger
Borrower journey	eSign, penny drop, mandate	=	Unchanged

03 How it works: seconds, end to end, no manual step

1

Existing journey

The loan is sanctioned and documents are eSigned exactly as they are today.

`No change for borrower`

2

Independent verification

The Registry checks the signed approval and documents. Amount and account come from signed evidence, not the request.

`Outside the lender`

3

Automated authorisation

The risk engine compares against the lender's baseline. The Registry signs a single-use DAT and logs it.

`Zero-touch`

4

Bank enforcement

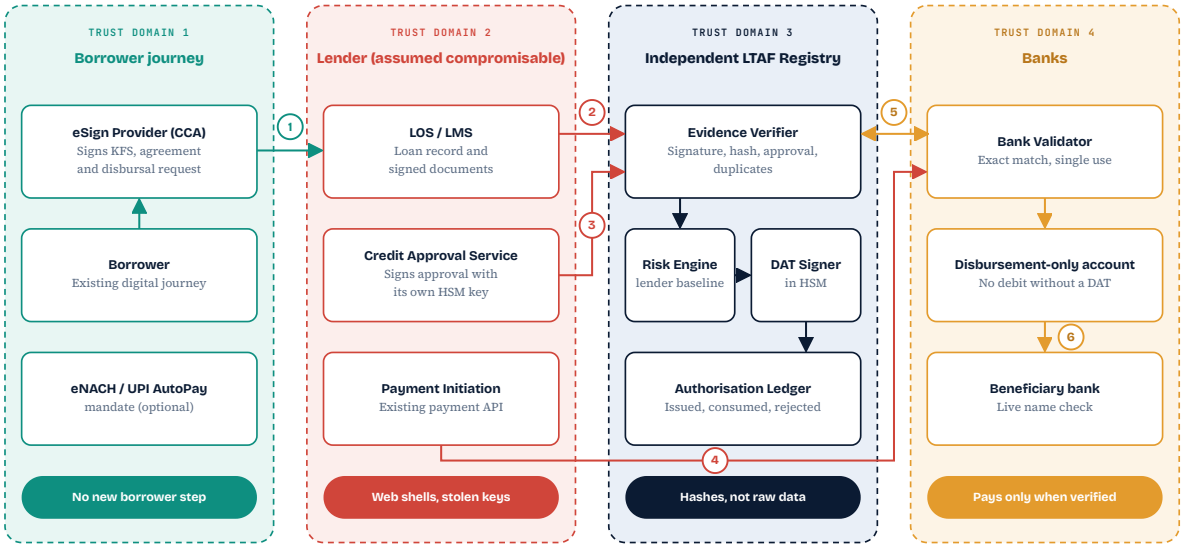
The bank pulls the DAT, matches every field, runs a live name check, pays and consumes the DAT.

`Every debit channel`

The payment instruction still travels through the existing API. The bank treats it as untrusted until the DAT matches. Latency target to be validated in a pilot.

04 Four trust domains. Assume the lender can be compromised.

LTAF works because verification, signing and the audit trail sit where the attacker cannot reach. The lender carries the evidence but is never trusted to vouch for it.



1 Signed documents to the lender

2 Signed documents and loan reference to the Registry

3 Approval evidence, signed with a separate key

4 Payment instruction, treated as untrusted

5 Bank pulls the DAT, then marks it consumed

6 Live name check, then payment

05 Would it have stopped October's attacks?

✓	**Dummy reference IDs with no matching loan**	`BLOCKED` No approved disbursement record, so no DAT.
✓	**Transfers above limits**	`BLOCKED` Amount is bound to the approved tranche.
✓	**Rapid transfers to mule accounts**	`BLOCKED` Beneficiary fails the live name check; circuit breaker as backstop.
✓	**Calls from whitelisted servers with stolen bank credentials**	`BLOCKED` The bank needs a DAT, whoever the caller is.
✓	**Debits on other channels of the same account**	`BLOCKED` Disbursement-only account rule.
~	**Deleted logs**	`MITIGATED` The authorisation trail sits outside the lender; the intrusion itself still needs conventional controls.

✓ blocked under the stated assumptions · ~ partly addressed. Indicative assessment, to be validated through adversarial testing.

DATA PROTECTION BY DESIGN

Aligned with the Digital Personal Data Protection Act, 2023 and DPDP Rules, 2025 [5]

Lender stays the data fiduciary

The Registry is its data processor under contract (purpose, security, breach notice, audit, deletion).

Consent notice

Loan consent notes independent verification of disbursals. One line, no new step.

Minimum data

Hashes and tokens only, never raw account numbers or borrower details.

No Aadhaar numbers

eSign signatures are verified; Aadhaar numbers are never stored.

Retention and use

Kept only as RBI record rules require; never reused for marketing or scoring.

Hosted in India

Registry data stays in India, in line with RBI payment-data expectations.

Uses data lenders already hold, for a related purpose, with less of it. Indicative view, not legal advice.

06 Five guardrails that close the side doors

Disbursement-only account
No debit without a valid DAT. Other outflows use a separate account.

Every channel
API, internet banking, bulk upload and branch all require the DAT.

Fail closed
If verification is unavailable or unclear, funds are held.

Circuit breakers
Lender baselines hold abnormal spikes; normal campaigns still flow.

Permitted payees only
Borrower's own account by default; dealers and builders from a verified payee master.

What LTAF does not do

- Prevent the initial intrusion. Patching, credential hygiene and endpoint protection still matter.
- Stop a genuine borrower colluding with an insider. That is credit fraud.
- Remove risk from the Registry itself, which must be engineered and assured as a high-value target.

Open questions

- Who should run the Registry: the disbursing bank, a specialist provider or a shared utility?
- Will an automated, independent check meet dual-approval expectations in RBI's 2026 NBFC cybersecurity directions [2]?
- What latency and cost per disbursement are acceptable at scale?

07 One payment, one token, used once

```
// signed by the Registry (JWS), verified by the bank
{
  "iss": "ltaf-registry",
  "jti": "dat_7Q2M9X",          // single use
  "loan_ref": "LN-20417",
  "tranche": "1/1",
  "amount": "500000.00", "ccy": "INR",
  "beneficiary": "tok_ab91…",    // hashed account
  "path": "A-borrower",
  "evidence": ["approval#9f3…", "rfd#c71…"],
  "exp": "+300s"
}
```

Example values for illustration only.

Bound to the exact payment
Loan, tranche, amount, currency and account. Change any field and the bank rejects it.

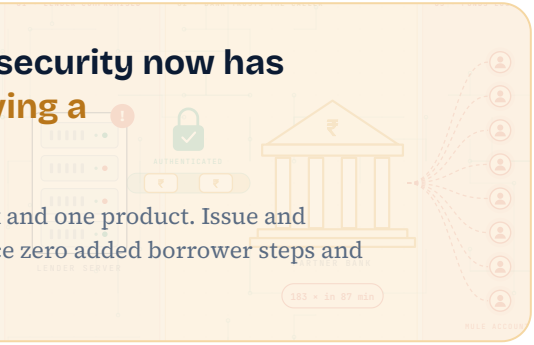
Short-lived and single use
Consumed atomically at the bank, so replays and concurrent attempts fail.

Evidence-backed
References the approval and signed documents the Registry verified, never raw borrower data.

Pulled by the bank
The lender never handles the token, removing the delivery channel as an attack surface.

Lending went digital on the speed of APIs. Its security now has to prove, independently, that every rupee leaving a disbursement account was meant to.

Next step: a shadow-mode pilot with one lender, one disbursing bank and one product. Issue and check DATs without enforcing them, then switch on enforcement once zero added borrower steps and red-team results are proven.



SOURCES

1. CERT-In, Advisory CIAD-2026-0046, 9 Oct 2026, updated 29 Oct 2026.
2. RBI (NBFC – Cybersecurity, Technology: Risk, Resilience and Assurance Framework) Directions, 2026, RBI/DoS/2026-27/461, 31 Jul 2026.
3. RBI (Digital Lending) Directions, 2025, 8 May 2025.
4. Elets BFSI citing The Economic Times, 29 Oct 2026; Siasat, 23 Oct 2026; Ministry of Cyber Affairs, 27 Oct 2026.
5. Digital Personal Data Protection Act, 2023 and DPDP Rules, 2025 (notified Nov 2025; phased rollout over 18 months).

Written by the author in a personal capacity. The views are his own and not those of any organisation. Incident figures are as reported by the cited sources. Not legal or regulatory advice.